# Open Source Contributions to Federal AI/SI Governance at CMS.gov

**Centers for Medicare & Medicaid Services**
**Open Source Program Office**

**https://github.com/DSACMS/decks/navaosssummit2026.pdf**









Natalia Luzuriaga
Louisa Sholar
Sachin Panayil
Dinne Kopelevich
Remy DeCausemaker

# What are the Centers for Medicare and Medicaid Services? (CMS)

"CMS is the United States federal agency that provides health coverage to more than **160 million** people through **Medicare, Medicaid**, the **Children's Health Insurance Program**, and the **Health Insurance Marketplace**."

CMS
CENTERS FOR MEDICARE & MEDICAID SERVICES

DIGITAL SERVICE AT CMS

https://cms.gov/about

# What is an Open Source Program Office? (OSPO)

An OSPO is responsible for defining and implementing programs, policies, and projects that guide inbound and outbound open source efforts at an organization.

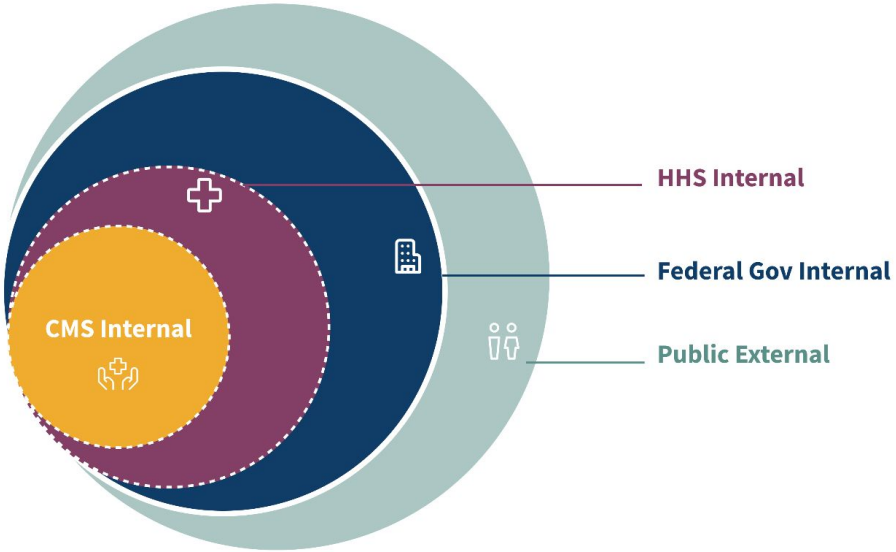
**30% of Fortune 100** companies have implemented an OSPO, and CMS is the ***first*** United States federal agency to implement this private-sector styled approach to an Open Source Strategy.




DIGITAL SERVICE AT CMS

https://github.blog/open-source/maintainers/why-companies-are-starting-ospos/

# What determines AI/SI Governance in the Federal Ecosystem?




AI/SI governance in the public sector is set by overlapping concentric layers of policies, regulations, memorandums, and laws.

Our Federal Government has **Memos** from the White House and **Laws** from Congress to follow for all Departments.

Our home Department (HHS) has policies to follow for all Operational Divisions (OpDivs).

Our Center (Medicare and Medicaid Services) has policies to follow for all offices and programs.

Our Open Source Program Office (OSPO) draws upon these policies, plus **open source best practices** from the external community, to harmonize our overall guidance.

# Federal & Agency-wide Policy Grid

| Policy | Level | Description |
|---|---|---|
| **America's AI Action Plan** | Federal | Executive Order 14179, “Removing Barriers to American Leadership in Artificial Intelligence”, directing the creation of an AI Action Plan |
| **Memorandum M-25-21** | Federal | Accelerating Federal Use of AI through Innovation, Governance, and Public Trust, establishes an AI Use Case inventory compiling all AI software projects across federal agencies |
| **Memorandum M-25-22** | Federal | Driving Efficient Acquisition of Artificial Intelligence in Government |
| **HHS M-25-21 Compliance Plan** | Agency/HHS | HHS created a Compliance Plan mirroring the pillars of the memos: driving AI innovation, improving AI governance and fostering public trust in federal use of AI |
| **HHS AI Strategy** | Agency/HHS | HHS is leading a whole-of-department transformation to make AI a practical layer of value across public health, health care delivery, biomedical research, human services, and agency operations — uniting Divisions through a “OneHHS” approach that shares data, tools, and infrastructure while protecting Americans’ privacy and earning public trust |

**Explore the guide:** https://dsacms.github.io/ospo-guide/outbound/ai/

# CMS Policy Grid

| Policy | Level | Description |
|---|---|---|
| **CMS AI Playbook** | OpDiv/CMS | The CMS AI Playbook documents the agency's evolving approach to AI adoption and maturity, offering CMS-specific guidance, tools, and frameworks for leadership, project teams, and IT and security professionals. |
| **CMS Technical Architecture Reference** | OpDiv/CMS | The TRA contains guidelines and recommended practices on AI-assisted development in the Software Development Lifecycle:<br>• AI Code Generation<br>• AI Principles for Developers<br>  ○ AI Code Generation Accountability<br>  ○ Tool Selection and Data Privacy Considerations<br>• AI Development Methodologies<br>  ○ "Vibe Coding" Policy Restrictions<br>  ○ Suitable Approaches to AI-Assisted Development<br>  ○ AI in the SDLC — Shifting Left: Integrating Quality and Security<br>• Examples of AI Benefits in the Software Development Lifecycle |

**Explore the guide:** https://dsacms.github.io/ospo-guide/outbound/ai/

# Which AI/SI-related risks are most connected to our OSPO's work?

| Risk | Mitigation | Resources |
| --- | --- | --- |
| Excess of low quality or extractive contributions/PRs to our open source projects | Contribution Guides and Guardrails | - OSPO GenAI Policy (DRAFT)<br>- CONTRIBUTING.md AI Usage Guidelines |
| AI/SI-enabled cyber attacks to our software supply chain and systems | Inbound review checklists; Automated vulnerability scanning and remediation | - Inbound Checklists<br>- Code Analysis Toolkit |
| Unwise or excessive usage of CMS resources | A plurality of HHS and CMS hosted tools and Models | - AI @ CMS Guide |
| Leakage of sensitive and personal data | Outbound Review Checklists and Automated Scanning tools | - Outbound Checklists via repo-scaffolder<br>- Code Analysis Toolkit |

# Which AI/SI-related risks are most connected to our OSPO's work?

| Risk | Mitigation | Resources |
|---|---|---|
| **Excess of low quality or extractive contributions/PRs to our open source projects** | **Contribution Guides and Guardrails** | - **OSPO GenAI Policy (DRAFT)**<br>- **CONTRIBUTING.md AI Usage Guidelines** |
| AI/SI-enabled cyber attacks to our software supply chain and systems | Inbound review checklists; Automated vulnerability scanning and remediation | - Inbound Checklists<br>- Code Analysis Toolkit |
| Unwise or excessive usage of CMS resources | A plurality of HHS and CMS hosted tools and Models | - AI @ CMS Guide |
| Leakage of sensitive and personal data | Outbound Review Checklists and Automated Scanning tools | - Outbound Checklists via repo-scaffolder<br>- Code Analysis Toolkit |

# CMS OSPO GenAI Contribution Policy (DRAFT)

https://dsacms.github.io/ospo-guide/outbound/gen-ai-policy
https://github.com/DSACMS/ospo-guide (patches welcome!)

# Why GenAI Contribution Guidelines and Disclosures?

- Repo governance was built to improve contributions ***from humans first***, but also happens limit extractive AI/SI contributions too!
- **Extractive Contributions** are when the effort put into a contribution does not meet or exceed the effort it takes to review that contribution, resulting in a net-loss of effort and time. (Shoutout Nadia Asparouhova, *Working In Public*)
- **Guidelines** and **Disclosures** turn extractive reviews from a high-effort one-off evaluations into a checklist. Checklists create structured spaces for intentional, repeatable participation that reduce cognitive and actual burden and effort.
- It's not Humans v.s. Machines, it's **Clarity v.s. Ambiguity.**

DIGITAL SERVICE AT CMS

**Explore the guide:** https://dsacms.github.io/ospo-guide/outbound/gen-ai-policy/#reducing-the-risk-of-extractive-contributions

# Guideline 1: Transparency and Disclosure

If AI/SI is used in your work, explicitly state **where** and **how** it was used in your pull request.

- **Acceptable**: Using AI/SI to gain understanding of existing code or to brainstorm solution ideas for an issue.
- **Acceptable**: Using AI/SI to translate or proofread your comments or PR descriptions, while maintaining your original thought and reasoning.

# Guideline 2: Human in the Loop

Using AI/SI does not change who's responsible for the code you submit. **A person remains accountable** for every one of their contributions, and AI/SI does not act on the project's behalf unsupervised.

- **Not Recommended:** Using external AI/SI tooling *(bots, agents)* to directly interact with the project, including creating issues, opening PRs, or commenting on GitHub.

# Guideline 3: Responsible Development and Code Quality

Using AI/SI does should not lower the quality of your code contributions.

- **Unacceptable**: Submitting AI/SI generated code you can't explain line by line to a developer, or using AI/SI output without fully understanding it or verifying it's the correct approach
- **Unacceptable**: Using AI/SI to increase the breadth of your contributions, such as spreading yourself across several projects at once. You provide more value by engaging deeply with one or two projects than shallowly with many.

# Guideline 4: Human Review and Validation

Using AI/SI should not result in a net loss of increasingly limited time and effort for human reviews.

- **Unacceptable**: Submitting a PR where the effort you put in, such as writing a prompt, is less than the effort it would take a maintainer to review it. We can already write prompts or run automated tools ourselves and doing that directly is faster and more secure than reviewing a low effort PR.

# Guideline 5: Pull Request Disclosures

We don’t accept PRs that:

- Don’t directly address an existing issue
- Touch more than X files at a time
- Contain more than Y commits
- Change core system files such as …
- Are untested / don’t pass our test suite / don’t pass our linters / don’t follow style guide

Please provide an explanation on how AI was used in the development of this pull request.

- ❑ Type of assistance:
  - ❑ Code generation
  - ❑ Documentation
  - ❑ Debugging
  - ❑ Testing
  - ❑ Refactoring
  - ❑ Other:
- ❑ Scope of usage: *Which files, functions, or sections were AI/SI-assisted*
- ❑ AI/SI System used:
  - ❑ ChatGPT
  - ❑ Claude
  - ❑ Gemini
  - ❑ GitHub Copilot
- ❑ Level of modification:
  - ❑ As-is
  - ❑ Modified
  - ❑ Used as inspiration
- ❑ Prompts used: *Please list or explain prompts that were used to develop this contribution*

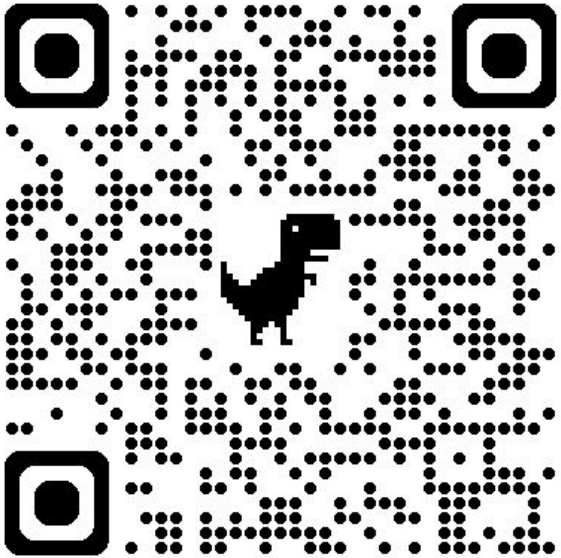


https://dsacms.github.io/ospo-guide/outbound/gen-ai-policy/#example-1-repositories-that-allow-ai-generated-contributions

# How does Repo Governance help?

| Risk | Mitigation |
| --- | --- |
| **Roadmap drift** | Limit PRs/Contributions to existing Tickets to prevent redirection of limited time, energy, attention from the established priorities of the project. |
| **Extractive Contributions** | Limit edits, commits, and file surface to reduce the '**splash radius**' of each contribution, and review time needed from a human. |
| **Breaking Changes** | Require **Test suites** to pass for a contribution to be merged |
| **Low Quality Contributions** | Require **Linters** to pass to ensure quality and standards are being adhered to, which also happens to reduce breaking changes, and wasted time and effort (and tokens!) |
| **Inconsistent Voice/Brand/Culture** | **Style Guides** establish non-code communications tone and standards. |
| **Expensive Reviews** | **Checklists** and **Templates** can be copy-pasted and automated to encourage contributions that follow guidelines, without needing to custom-respond to every PR. |

# Thank you Nava Open Source Summit 2026!



https://github.com/DSACMS/decks/blob/main/navaosssummit2026.pdf

creative commons

PUBLIC DOMAIN

## Questions or Comments?

https://go.cms.gov/ospo

**Open Source Questions?**
opensource@cms.hhs.gov

**Digital Service Questions?**
DigitalService@cms.hhs.gov

## Help Answer The Call!

**Digital Service at CMS.gov**
https://cms.gov/digital-service

**DigitalCorps Fellowships**
https://digitalcorps.gsa.gov

**CodingItForward Summer Internships**
https://codingitforward.com

## AI/SI Governance Resources

- Linux Foundation State of the OSPOs 2026
- CMS SI/AI Playbook
- CMS OSPO Guide: GenAI Usage Guidance
- CMS Technical Reference Architecture (TRA)
- CMS SHARE IT Act Landing Page